

CoreAxis Technologies

Information Technology Department Handbook

Head Office

Chennai, Tamil Nadu, India

Branch Office

Bengaluru, Karnataka, India

01

Welcome to the Information Technology Department

This handbook is the authoritative reference for all personnel within the Information Technology department at CoreAxis Technologies. It establishes the operational standards, governance frameworks, security policies, and procedural guidelines that govern how IT services are delivered, maintained, and secured across the organization.

CoreAxis Technologies operates as a hybrid-mode enterprise developing AI-powered software, RAG systems, LLM applications, cloud-native platforms, intelligent automation solutions, computer vision applications, and data analytics products. The IT department is responsible for the infrastructure, platforms, and services that enable this work to proceed securely, reliably, and at scale.

This document is intended for IT Administrators, System Administrators, Network Engineers, Cloud Administrators, Help Desk Engineers, and IT Support Engineers. It is not a training manual or introductory guide — it assumes professional-level competency in each role's domain. Where this handbook specifies a standard, that standard is mandatory unless a documented exception has been approved through the Change Management process.

Sections referencing third-party technologies (Microsoft 365, AWS, Azure, CrowdStrike, etc.) describe approved usage within CoreAxis's environment. Approved does not mean unconditional — all technologies are subject to the governance, security, and licensing policies defined herein.

Questions regarding interpretation or applicability of any policy in this handbook should be directed to the Head of Information Technology. Requests to modify policies must follow the Change Management process defined in Section 24.

02

Department Overview

The IT department at CoreAxis Technologies supports approximately 100 employees across two offices — the Head Office in Chennai, Tamil Nadu, and the Branch Office in Bengaluru, Karnataka. The department operates Monday through Friday, 09:00–17:00 IST, with on-call provisions for critical incidents as defined in the Incident Management policy.

The department is structured to deliver services across five operational domains:

Infrastructure and Operations — Responsible for the physical and virtual infrastructure underpinning all CoreAxis services. This includes server management, network operations, storage systems, virtualization platforms (VMware, Hyper-V), and data centre or colocation facilities.

Cloud and Platform Engineering — Manages the organization's cloud footprint across AWS and Azure. Responsibilities include cloud resource provisioning, cost governance, security posture management, and platform reliability.

End-User Computing and Service Desk — Delivers device lifecycle management, user support, onboarding provisioning, and first- through third-line support services across all offices and for remote employees.

Identity and Access Management — Governs user accounts, directory services, role-based access controls, privileged access, MFA enforcement, and offboarding procedures through Microsoft Entra ID and on-premises Active Directory.

Information Security Operations — Coordinates with the Information Security department to enforce endpoint security baselines, manage EDR tooling, oversee patch compliance, and respond to security incidents.

The IT department interfaces regularly with HR for onboarding and offboarding workflows, with Finance for procurement and asset capitalization, with Information Security for compliance and audit activities, and with all technical departments for infrastructure requirements and tooling support.

All IT services are underpinned by the principle of operational stability — changes are controlled, monitored, and reversible wherever possible. The department adheres to

continuous improvement practices and conducts quarterly reviews of operational metrics, service desk performance, and security posture.

03

Team Structure and Roles

The IT department is organized into defined roles with distinct responsibilities and reporting lines. Each role carries specific accountabilities outlined below.

IT Administrator

The IT Administrator oversees the day-to-day operations of IT systems and ensures the continuity of services across both offices. Responsibilities include managing Active Directory and Microsoft Entra ID tenants, overseeing user account provisioning and deprovisioning, administering Microsoft 365 and Google Workspace environments, coordinating patch management schedules, managing software licensing inventories, and maintaining configuration documentation.

The IT Administrator holds administrative rights across identity platforms and is responsible for enforcing access control policies. All privilege escalations beyond standard user accounts must be documented and approved by the Head of IT. The IT Administrator reports directly to the Head of IT and is the primary escalation point for IT Administrators and Help Desk Engineers.

System Administrator

System Administrators are responsible for the stability, performance, and security of server infrastructure — both on-premises and cloud-hosted. Responsibilities include provisioning and maintaining Windows Server and Ubuntu Linux systems, managing virtualization platforms (VMware vSphere, Microsoft Hyper-V), administering database services (PostgreSQL, Redis), maintaining Nginx reverse proxies and API gateway configurations, overseeing backup and recovery operations, and implementing OS-level security hardening per CIS baselines.

System Administrators hold elevated privileges on server infrastructure. All changes to production server configurations require a Change Request approved through the Change Management process. System Administrators are expected to maintain system documentation, including current topology diagrams and runbooks for all managed services.

Network Engineer

Network Engineers design, implement, and maintain the network infrastructure supporting both offices and hybrid connectivity. Responsibilities include managing LAN, WAN, and SD-WAN configurations, operating firewall policies and intrusion prevention systems, managing VPN concentrators and client access, overseeing network segmentation (VLANs, DMZ, guest networks), monitoring bandwidth utilization and QoS policies, and coordinating with ISPs for circuit management and SLA enforcement.

Network Engineers maintain network topology documentation and are responsible for enforcing the network security standards defined in this handbook. Changes to firewall rule sets, routing configurations, or network topology require a Change Request. Network Engineers participate in incident response for network-related events and maintain out-of-band management capabilities for critical network devices.

Cloud Administrator

Cloud Administrators manage CoreAxis's cloud infrastructure across AWS and Azure. Responsibilities include provisioning and maintaining cloud resources (virtual machines, managed databases, storage accounts, load balancers, container services), enforcing cloud security posture through AWS Security Hub and Microsoft Defender for Cloud, managing IAM roles and service principals, overseeing cost governance and budget alerting, maintaining infrastructure-as-code templates (Terraform, Bicep, or CloudFormation as applicable), and coordinating with development teams for infrastructure requirements.

Cloud Administrators operate under the principle of least privilege for cloud IAM and do not hold standing administrative access to production cloud environments. Privileged operations in production require time-limited role assignments with audit logging. All cloud infrastructure changes in production environments must be code-reviewed and deployed through the approved CI/CD pipeline or a documented Change Request.

Help Desk Engineer

Help Desk Engineers provide first- and second-line support to all CoreAxis employees. Responsibilities include receiving, triaging, and resolving support tickets via the Jira Service Management portal, provisioning and imaging employee devices per the Laptop Provisioning Standard, resetting passwords and managing MFA device enrollment, troubleshooting endpoint hardware and software issues, managing peripheral devices and accessories, coordinating with third-party vendors for hardware warranty claims, and escalating unresolved incidents to System Administrators or Network Engineers as appropriate.

Help Desk Engineers interact directly with end users and are expected to maintain professional communication standards at all times. Ticket resolution times are governed by the SLAs defined in the IT Service Desk Procedures. Help Desk Engineers do not have standing administrative rights to production systems — privilege escalation is handled through documented procedures.

IT Support Engineer

IT Support Engineers operate at a second- to third-line level, providing deeper technical support across infrastructure, application, and network domains. Responsibilities include handling escalated tickets from Help Desk Engineers, supporting deployments of enterprise applications, maintaining internal tooling and automation scripts, assisting with security incident investigation and containment, participating in Change Advisory

Board reviews, maintaining and testing disaster recovery procedures, and producing knowledge base articles for recurring issues.

IT Support Engineers collaborate closely with System Administrators and Network Engineers and may be assigned project-based responsibilities for infrastructure initiatives. They are expected to maintain current professional certifications relevant to their domain and contribute to the department's continuous improvement program.

04

IT Governance

IT governance at CoreAxis Technologies is structured around four pillars: policy enforcement, change control, audit readiness, and risk management. The IT department is accountable for ensuring that technology assets, platforms, and practices align with organizational objectives and security obligations.

Policy Hierarchy

All IT policies originate from the Head of IT and are reviewed annually or when triggered by a material change in business operations, regulatory environment, or threat landscape. This handbook constitutes the top-level IT policy document. Subordinate standards, procedures, and guidelines are maintained in Confluence under the IT Knowledge Base space.

Change Advisory Board (CAB)

The Change Advisory Board meets weekly and is composed of the Head of IT, the IT Administrator, at least one System Administrator, and a representative from the Information Security department. The CAB reviews and approves standard and significant change requests. Emergency changes may be implemented with post-hoc CAB review within 24 hours.

Audit and Compliance

The IT department maintains audit logs for all privileged operations, configuration changes, and access events. Logs are retained for a minimum of 12 months in accordance with internal data governance requirements. The department cooperates with internal and external auditors and provides evidence packages upon request. Audit findings are tracked in Jira and resolved within the timelines agreed with the audit function.

Risk Register

The IT department maintains a risk register covering infrastructure, cloud, endpoint, identity, and third-party risks. Risks are assessed quarterly using a likelihood-impact matrix. High-rated risks require a documented mitigation plan with assigned ownership and a target resolution date. The risk register is reviewed by the Head of IT and shared with the CISO quarterly.

Technology Standards Committee

New technology proposals — platforms, tools, SaaS applications, or open-source components — must be reviewed by the Technology Standards Committee before adoption. The committee includes representatives from IT, Information Security, and the

relevant business function. Review criteria include security posture, licensing cost, supportability, integration requirements, and data sovereignty implications.

05

Employee Device Management

CoreAxis Technologies manages employee devices through a centralized lifecycle process that covers procurement, provisioning, usage governance, and decommissioning. All devices issued to employees are corporate assets and are subject to the policies in this handbook.

Device Issuance

Devices are issued to employees upon joining or at role change, as approved by HR through the onboarding workflow. Standard device specifications are defined in Section 6. Employees sign an Asset Acknowledgement form upon receiving a device, confirming receipt and their responsibility for its care and compliance with usage policies.

Enrollment and Configuration

All issued devices must be enrolled in the organization's Mobile Device Management (MDM) platform before use. Enrollment enforces encryption, screen lock policies, OS update requirements, and certificate-based Wi-Fi authentication. Devices that are not MDM-enrolled are not permitted to connect to corporate network resources.

Personal Use

Corporate devices may be used for incidental personal activity provided it does not violate the Acceptable Use Policy, does not involve the installation of unauthorized software, and does not compromise the security baseline of the device. Personal storage of sensitive personal data on corporate devices is discouraged. Employees should not use corporate devices as their primary personal device.

Device Return

Devices must be returned to IT upon resignation, termination, or role change requiring a different device class. IT will perform a factory reset and re-image the device before reissuing. Employees must not perform factory resets themselves. Data recovery from returned devices will not be performed unless directed by HR or Legal.

Lost or Stolen Devices

Employees must report lost or stolen devices to the IT Service Desk and their line manager within four hours of discovery. IT will initiate a remote wipe via MDM immediately upon report. Repeated loss incidents may result in the employee bearing the cost of replacement, subject to HR review.

06

Laptop and Workstation Standards

CoreAxis Technologies defines hardware specifications for employee devices based on role requirements. Deviations from these standards require approval from the Head of IT.

Standard Workstation (Tier 1 — Office/Administrative)

Applicable to: HR, Finance, and general administrative roles.

- CPU: Intel Core i5 (12th Gen or later) or AMD Ryzen 5 (5000 series or later)
- RAM: 16 GB DDR4 or DDR5
- Storage: 512 GB NVMe SSD
- Display: 15.6" FHD or external monitor with docking station
- OS: Windows 11 Enterprise

Developer/Engineering Workstation (Tier 2)

Applicable to: Software Engineering, AI & ML, and IT roles.

- CPU: Intel Core i7/i9 (13th Gen or later) or AMD Ryzen 7/9 (7000 series or later)
- RAM: 32 GB DDR5 (64 GB available upon approval)
- Storage: 1 TB NVMe SSD (upgradeable)
- GPU: Discrete GPU for ML workloads — NVIDIA RTX 4060 or higher (upon approval)
- OS: Windows 11 Enterprise (dual-boot Ubuntu Linux 22.04 LTS available upon request)
- Accessories: External monitor (27" 1440p minimum), mechanical or ergonomic keyboard, precision mouse

Network/Server Operations Workstation (Tier 3)

Applicable to: Network Engineers, System Administrators, Cloud Administrators.

- Specifications align with Tier 2 above, with addition of console serial adapters and network diagnostic toolkits as required.

Peripheral Standards

- Monitors: Dell or LG IPS panels; minimum 1080p, preferred 1440p
- Webcams: Minimum 1080p for remote meeting participants
- Headsets: USB or 3.5mm; selected from the approved peripherals list maintained in Confluence
- Docking Stations: Thunderbolt 4 or USB-C PD docks from the approved list

Device Naming Convention

All devices are named using the format: CAX-[OFFICE]-[ROLE]-[SEQ]

- Example: CAX-CHN-DEV-042 (Chennai office, Developer, unit 042)
- Office codes: CHN (Chennai), BLR (Bengaluru)
- Role codes: DEV (Developer/Engineering), ADM (Administrative), NET (Network), OPS (Operations), IT (IT staff)

Naming is assigned by IT at provisioning time and registered in the asset inventory system.

Operating System Standards

CoreAxis Technologies maintains a curated set of approved operating systems for all device categories. Unapproved operating systems may not be installed on corporate devices without formal approval.

Approved Operating Systems

Windows 11 Enterprise

The primary desktop OS for all employee workstations. CoreAxis licenses Windows 11 Enterprise through Microsoft Volume Licensing. Key configuration requirements:

- All devices must be Azure AD joined (or Hybrid AD joined where applicable)
- BitLocker full-disk encryption must be enabled with recovery keys escrowed to Azure AD
- Windows Defender must remain active; any EDR replacement (CrowdStrike Falcon) must be configured before disabling Defender
- Automatic Windows Update must be managed via Windows Update for Business, deferring feature updates by 30 days and quality updates by 7 days
- Windows Firewall must remain enabled; inbound connections must be restricted to approved services only

Ubuntu Linux 22.04 LTS

Approved for Developer and IT roles requiring Linux environments. Configuration requirements:

- Full-disk encryption (LUKS) must be enabled at installation

- UFW firewall must be enabled with default-deny inbound policy
- Systems must be enrolled in endpoint management with osquery or equivalent telemetry agent
- Unattended-upgrades must be configured for security updates
- Root password-based SSH must be disabled; key-based authentication only
- Systems must be joined to the corporate directory where technically feasible

Ubuntu Server 22.04 LTS / 24.04 LTS

The approved server OS for on-premises and cloud-hosted Linux servers. CIS Level 1 hardening benchmarks apply. Ubuntu Pro subscriptions are used to extend security maintenance coverage.

Windows Server 2022

The approved Windows Server OS for on-premises Active Directory domain controllers, file servers, and Windows-based application servers. CIS benchmarks for Windows Server 2022 apply.

OS Lifecycle Policy

Operating systems must be on a supported release at all times. Six months before end-of-support, the IT department initiates an upgrade assessment. Devices still running unsupported OS versions after the end-of-support date are quarantined from the corporate network pending remediation.

Virtual Machine OS Templates

Approved VM templates are maintained in the VMware content library and Azure Shared Image Gallery. All templates are pre-hardened and updated quarterly. Custom OS images must be derived from approved templates, not built from scratch.

08

Software Installation Policy

Software installation on corporate devices is governed by an approved application catalog. Employees may not install software from outside the approved catalog without prior authorization.

Approved Application Catalog

The approved application catalog is maintained in Confluence and includes all standard productivity software, development tools, communication platforms, and utilities authorized for use at CoreAxis. The catalog specifies the approved version range, licensing type, and whether installation requires administrator privileges.

Installation Process

Standard applications from the approved catalog are deployed via Microsoft Endpoint Configuration Manager (MECM) for Windows devices or managed via an MDM policy script for Linux endpoints. Employees should not need administrator rights to install approved software — all catalog applications are deployed silently by IT.

Requesting New Software

Employees requiring software not in the approved catalog submit a Software Request ticket in Jira. The request must include the software name, version, vendor, justification, cost, and whether it requires data access. The IT Administrator reviews the request in conjunction with the Information Security team. Approval is typically returned within five business days. Upon approval, the software is added to the catalog and deployed.

Prohibited Software Categories

The following categories of software are prohibited on all corporate devices regardless of approval status:

- P2P file sharing clients (BitTorrent clients, eMule, etc.)
- Anonymizing proxies, VPN clients not provisioned by IT, Tor browser
- Unapproved remote access tools (AnyDesk, TeamViewer installed without IT authorization)
- Cryptocurrency mining software
- Unlicensed or cracked software of any kind
- Software sourced from unofficial repositories or file-sharing sites

Developer Tooling

Development teams use a curated set of tools including Docker Desktop, VS Code, JetBrains IDEs, Git, GitHub Desktop, Node.js, Python, and Conda. These are maintained in the developer catalog. Package managers (pip, npm, brew) may be used freely for development dependencies within project environments; system-level package installations require approval.

Script and Binary Execution Policy

PowerShell execution policy is set to RemoteSigned on all Windows devices. Scripts downloaded from the internet must be code-signed by a trusted publisher or explicitly approved by IT before execution. On Linux endpoints, executables downloaded from external sources should be verified against published checksums before execution.

09

User Account Management

User accounts at CoreAxis Technologies are managed through a centralized lifecycle process anchored in Microsoft Entra ID (Azure Active Directory) with synchronization to on-premises Active Directory where applicable.

Account Provisioning (Onboarding)

HR initiates the onboarding workflow in Jira when a new employee's start date is confirmed. The IT Administrator receives an automated task to create the user account no later than two business days before the start date. Provisioning includes:

- Entra ID account creation with MFA pre-enrollment
- Assignment to appropriate security groups based on department and role (as specified by the HR onboarding form)
- Mailbox provisioning (Microsoft 365 or Google Workspace as applicable)
- Jira, Confluence, GitHub Enterprise, and Slack account creation
- Device assignment and shipping (if remote) or desk preparation (if office-based)

Account Naming Convention

User accounts follow the format: firstname.lastname@coreaxis.com

Where name conflicts exist, append a numeral: firstname.lastname2@coreaxis.com

Display names use: Firstname Lastname (Department)

Access Assignment

Access is assigned based on the principle of least privilege. Role-based access groups are predefined per department and job function. Managers may not self-authorize access grants beyond their team's standard entitlements. All access assignments are logged.

Account Modification

Access changes resulting from promotions, transfers, or project assignments are requested via the Access Request workflow in Jira, approved by the employee's manager and reviewed by the IT Administrator. Access from the previous role is revoked within two business days of the change.

Account Deprovisioning (Offboarding)

HR notifies IT of departures with a minimum of three business days' notice for resignations, and immediately for terminations. Upon notification:

- The account is disabled immediately (terminations) or on the last working day (resignations)
- All active sessions are invalidated via Entra ID
- MFA methods are removed
- Mailbox access is delegated to the line manager for 30 days, then archived

- Licensed software seats are released
- Device collection is coordinated with HR
- All accounts across all systems are disabled or deleted per the system-specific offboarding checklist

Offboarding checklists are maintained in Confluence and must be completed and signed off by the IT Administrator within five business days of the departure date.

Dormant Account Policy

Accounts inactive for 60 consecutive days are automatically flagged for review.

Following review and manager confirmation, accounts are disabled. Accounts inactive for 90 days are disabled without review. Disabled accounts are deleted after 180 days unless a legal hold is in place.

10

Identity and Access Management (IAM)

CoreAxis Technologies implements Identity and Access Management through Microsoft Entra ID as the primary identity platform, integrating with on-premises Active Directory via Entra Connect where required.

Core Principles

- **Least Privilege:** Access rights are the minimum required to perform job functions. No standing administrative access is permitted for routine operational tasks.

- **Role-Based Access Control (RBAC):** Access is assigned via security groups aligned to job roles, not directly to individual users. Group membership is reviewed quarterly.
- **Separation of Duties:** Administrative accounts are separate from standard user accounts. No IT staff member uses their administrative account for email, browsing, or daily productivity tasks.
- **Just-In-Time Access:** Privileged Identity Management (PIM) in Entra ID is used for all Entra admin roles and Azure RBAC roles. Privilege activation requires justification and generates an audit log entry.

Account Tiers

- **Tier 0 — Global/Tenant Administrators:** Reserved for Entra Global Admin and equivalent. Maximum two accounts; usage triggers immediate alerting. Used only for break-glass scenarios.
- **Tier 1 — Infrastructure Administrators:** System Administrators, Network Engineers, Cloud Administrators with elevated rights on infrastructure. PIM-activated roles only; no standing assignment.
- **Tier 2 — Service Administrators:** Help Desk Engineers with limited elevated rights (password resets, MDM management). Standing role assignment is acceptable at this tier.
- **Tier 3 — Standard Users:** All other employees. No elevated rights.

Service Accounts

Service accounts are created for application-to-application authentication and automated processes. Requirements:

- Managed Service Accounts (MSA) or Entra ID Service Principals are preferred over interactive user accounts
- Service account passwords (where applicable) are managed via a secrets manager or Azure Key Vault
- Service accounts must not be used for interactive login
- Service account permissions are documented and reviewed annually

Access Reviews

Entra ID Access Reviews are configured quarterly for all privileged roles and annually for standard group memberships. Managers confirm or deny access continuity for their direct reports. Access not confirmed within the review window is revoked automatically.

11

Password Policy

CoreAxis Technologies enforces the following password standards across all systems and accounts managed by IT.

Standard User Accounts

- Minimum length: 14 characters
- Complexity: Must include uppercase, lowercase, numerals, and special characters
- Password expiry: 90 days for accounts without MFA; no mandatory expiry for accounts with MFA enabled (per NIST SP 800-63B guidance)
- History: Passwords may not match the previous 12 passwords

- Account lockout: 5 failed attempts triggers a 30-minute lockout (automated unlock); 10 consecutive failed attempts requires Help Desk intervention

Privileged Accounts

- Minimum length: 20 characters
- Password expiry: 60 days
- All privileged account password changes are logged with timestamps

Passphrase Approach

The IT department encourages the use of passphrases over complex short passwords. A passphrase of four or more unrelated words (e.g. "turbine.marble.census.flask") meeting the minimum length requirement is acceptable and typically more resistant to brute-force attacks.

Password Manager

All employees are provided access to the approved corporate password manager. Employees must use the password manager to generate and store unique passwords for all corporate accounts. Reuse of passwords across corporate accounts is prohibited. The IT department does not specify which password manager beyond confirming the approved tool in the application catalog.

Default Credentials

Default factory credentials on any device, service, or application must be changed before the device or service is placed into production or connected to the corporate network. The IT department maintains a default credential audit as part of the quarterly vulnerability assessment.

Password Sharing

Password sharing between individuals is prohibited. Shared service access must be implemented via shared accounts with individual audit trails (where the platform supports it), or via role-based service accounts. Where a platform does not support individual audit trails for shared access, an access waiver must be submitted and approved.

12

Multi-Factor Authentication (MFA)

Multi-Factor Authentication is mandatory for all CoreAxis user accounts that access corporate resources. There are no blanket exemptions.

MFA Methods (in order of preference)

1. FIDO2 hardware security key (YubiKey or equivalent) — required for Tier 0 and Tier 1 accounts
2. Microsoft Authenticator app (push notification or TOTP) — standard for Tier 2 and Tier 3 accounts
3. TOTP authenticator app (Authy, Google Authenticator) — acceptable where Microsoft Authenticator is not supported
4. SMS OTP — not approved for corporate accounts (deprecated due to SIM-swap risk)
5. Voice call OTP — not approved

MFA Enrollment

MFA enrollment is completed during onboarding as part of the account provisioning process. The IT department pre-registers the employee's account in a temporary access pass state and provides enrollment instructions. Employees must complete MFA registration on their first login.

Conditional Access Policies

Entra ID Conditional Access enforces MFA based on the following conditions:

- All access from outside the corporate network requires MFA, regardless of application
- Access to privileged applications requires MFA on every session, regardless of network location
- Legacy authentication protocols (IMAP, POP3, basic auth) are blocked for all accounts
- Sign-in risk policies escalate authentication requirements for high-risk sign-in events

MFA Recovery

Lost or inaccessible MFA devices are recovered through the IT Service Desk via identity verification (government ID and manager confirmation). Recovery is logged and flagged for security review. Temporary access passes are issued with a maximum validity of 24 hours.

MFA for Service Accounts

Service Principals and managed identities use certificate-based authentication or client secrets stored in Azure Key Vault. MFA in the interactive sense does not apply, but all authentication events are logged and monitored for anomalies.

13

VPN Access Policy

CoreAxis Technologies operates a corporate VPN service to provide secure remote access to internal resources for employees working outside of office locations.

Approved VPN Solution

The IT-managed VPN solution is the sole approved VPN for accessing corporate resources remotely. Employees must not install or use third-party VPN clients on corporate devices to access corporate systems. Personal VPN services on corporate devices are prohibited as they may intercept corporate traffic.

VPN Access Requirements

- VPN client must be installed and managed by IT (not self-installed)
- Connection requires valid Entra ID credentials and MFA
- Split tunneling is disabled by default; all traffic is routed through the corporate gateway during VPN sessions

- VPN client enforces a compliant device health check (OS patch level, antivirus status, MDM enrollment) before allowing connection

Access Tiers

- **Standard Remote Access:** Provides access to internal applications, file shares, and collaboration tools. Available to all employees. Requires standard MFA.
- **Privileged Remote Access:** Required for administrative access to servers, network devices, and cloud management consoles from outside the office. Requires hardware security key MFA and session logging.

VPN Usage Governance

VPN connection logs are retained for 90 days and reviewed by the IT Administrator weekly for anomalous connection patterns. Concurrent connections from geographically disparate locations trigger an automatic security alert. VPN access from countries not approved in the travel policy requires advance notification to IT and Information Security.

Contractor and Third-Party Access

Contractors do not receive standard VPN credentials. Third-party access to internal systems is provided through isolated jump hosts or dedicated access accounts with time-limited credentials, reviewed and approved by the Head of IT for each engagement.

Network Infrastructure Standards

CoreAxis Technologies maintains a structured network infrastructure supporting both office locations. Network design follows the principle of defense-in-depth with multiple security layers and clear segmentation between trust zones.

Network Topology

Each office operates a three-tier architecture: Core (routing and inter-VLAN), Distribution (aggregation), and Access (end-user and device connectivity). Core switches are high-availability pairs with link aggregation. WAN connectivity between offices uses encrypted site-to-site VPN tunnels over dedicated MPLS circuits with public internet as a redundant path.

VLAN Segmentation

Traffic is segmented into named VLANs per zone. Standard segments include:

- Corporate LAN (employee workstations and managed devices)
- Server LAN (internal servers, domain controllers)
- Management LAN (network devices, OOB management, IPMI/iDRAC interfaces)
- DMZ (publicly accessible services, reverse proxies)
- Guest Wi-Fi (visitor internet access, isolated from corporate)
- IoT/Physical Security (access control, cameras — isolated segment)
- VoIP (quality-of-service prioritized)

Inter-VLAN routing is controlled by firewall ACLs. No VLAN may route directly to another without explicit firewall policy approval. The Management LAN is accessible only from specific administrative workstations.

Firewall Policy

The default firewall policy is deny-all inbound, permit-all outbound. Outbound traffic is subject to URL filtering and application inspection. All firewall rule changes require a Change Request with justification. Rule sets are reviewed quarterly, and rules with no matched traffic in 90 days are flagged for removal.

DNS and DHCP

Internal DNS is served by dedicated Microsoft DNS servers integrated with Active Directory. Public DNS resolvers are not permitted for internal clients. DHCP scopes include DHCP snooping to prevent rogue server attacks. DNS query logs are retained for 30 days.

Network Device Hardening

All network devices (switches, routers, firewalls) are configured per the vendor's hardening guide and applicable CIS benchmarks. Unused ports are disabled. Default credentials are changed at provisioning. SNMPv3 is used where SNMP monitoring is required; SNMPv1 and SNMPv2c are prohibited.

15

Wi-Fi and Remote Access

Corporate Wi-Fi

Corporate wireless networks operate on the 5 GHz band (802.11ac/ax) and use WPA3-Enterprise authentication backed by RADIUS and certificate-based EAP-TLS. Passwords or pre-shared keys are not used for corporate SSID authentication. Devices must be MDM-enrolled and certificate-provisioned to connect to the corporate SSID.

Wi-Fi access points are managed centrally via a wireless LAN controller. Rogue AP detection is active and alerts the network team upon detection. Wireless clients are isolated from each other (client isolation enabled on corporate SSIDs).

Guest Wi-Fi

A separate guest SSID provides internet-only access. Guest networks are rate-limited, content-filtered for basic safety, and completely isolated from the corporate network. Guest credentials rotate daily and are available at reception. Employees requiring internet access for personal devices should use the guest network rather than connecting personal devices to the corporate SSID.

Remote Office Connectivity

Remote employees connecting from home or co-working spaces must use the corporate VPN (Section 13) for all access to internal resources. IT provides a brief home network security advisory for remote employees covering router firmware updates, WPA3 or WPA2 usage, and guest network isolation for personal devices.

Wired Access Control

802.1X authentication is enforced on all wired switch ports in the corporate segment. Unauthenticated devices are placed in a quarantine VLAN with access only to the IT

remediation portal. Physical security of network access points is maintained through secure telecommunications closets.

16

Email and Collaboration Tools

CoreAxis Technologies operates an integrated collaboration ecosystem covering email, messaging, video conferencing, project management, and documentation.

Primary Communication Channels

- **Email:** Microsoft 365 Exchange Online (primary communication platform)
- **Instant Messaging:** Slack (internal team communication)
- **Video Conferencing:** Microsoft Teams (external calls, all-hands, client meetings) and Slack Huddles (informal internal calls)
- **Project Tracking:** Jira
- **Documentation:** Confluence
- **Code Repository:** GitHub Enterprise

Email Security

Exchange Online Protection (EOP) and Microsoft Defender for Office 365 are configured with the following controls:

- SPF, DKIM, and DMARC records are published and enforced
- Anti-phishing policies with impersonation protection are enabled
- Safe Links rewrites all URLs in email for real-time scanning
- Safe Attachments detonates suspicious attachments in a sandbox before delivery
- External email is tagged with an [EXTERNAL] banner in the subject line
- Bulk mail filtering is set to aggressive to reduce spam delivery

Email Usage Policy

Corporate email accounts are for business purposes. Personal use is incidental only. Employees must not use personal email accounts to transmit corporate data. Mass email campaigns (marketing, announcements) require IT configuration of an approved sending domain and tool.

Collaboration Platform Governance

Slack workspace access is controlled via SSO through Entra ID. Channel creation is open to all employees for non-sensitive topics; channels containing confidential project data must have appropriate access restrictions. Slack message retention is set to 12 months. The Slack administrator reviews public channel membership quarterly.

GitHub Enterprise access is provisioned per team and repository requirements by the IT Administrator in coordination with team leads. Repository visibility is private by default. External collaborator access requires Head of IT approval.

Microsoft 365 / Google Workspace Usage

CoreAxis Technologies operates Microsoft 365 as the primary productivity suite, with Google Workspace in use for select teams. Governance standards apply to both platforms.

Microsoft 365

The Microsoft 365 tenant is managed by the IT Administrator with Global Admin rights held in break-glass accounts only. Administrative tasks are performed via delegated admin roles using PIM. Standard configurations include:

- Conditional Access policies enforcing MFA, compliant devices, and named locations
- DLP policies preventing external sharing of documents classified as Confidential or above
- Teams policies controlling external federation and guest access
- SharePoint Online as the primary document management platform for non-code assets
- OneDrive for Business for individual file storage, with 1 TB allocation per user
- Power Automate and Power Apps usage requires IT review before use in production workflows

Google Workspace

Google Workspace is provisioned for specific team functions. SSO is configured via Entra ID as the identity provider. Google Drive sharing policies are set to restrict

external sharing to approved domains only. Google Workspace super-admin access is held under the same break-glass controls as Microsoft 365.

Data Retention

Microsoft 365 retention policies are configured in Microsoft Purview:

- Email: 7-year retention
- Teams messages: 3-year retention
- SharePoint and OneDrive: 5-year retention with version history

Retention policies cannot be overridden by individual users. Legal hold requests from Legal or HR must be submitted to IT via a formal request; IT will configure appropriate eDiscovery holds.

Licensing Management

The IT Administrator maintains a license inventory spreadsheet reconciled monthly against Entra ID active user counts. Unused licenses are reclaimed within 30 days of account deprovisioning. License procurement requests go through the Hardware Procurement Process (Section 21) for budget approval.

18

File Storage and Sharing Standards

CoreAxis Technologies defines approved file storage locations based on data classification and access requirements.

Storage Hierarchy

- **SharePoint Online:** Team and project document libraries; the primary location for documents requiring collaborative access or version control
- **OneDrive for Business:** Individual work files; not intended for team-shared content
- **GitHub Enterprise:** All code, infrastructure-as-code, and configuration files — source control is mandatory for these categories
- **AWS S3 / Azure Blob Storage:** Application data, ML training datasets, and large binary artifacts — access controlled via IAM policies and reviewed quarterly
- **On-Premises File Server:** Legacy shared drives maintained for specific business units with migration underway; no new data classifications should be placed in on-premises file shares

Data Classification

CoreAxis operates a four-tier data classification:

- **Public:** No restrictions on external sharing
- **Internal:** Shareable within the organization; not intended for external distribution
- **Confidential:** Restricted to named teams or roles; must not be shared externally without approval
- **Restricted:** Highest sensitivity (key material, PII, financial records, model weights, contractual data); requires encrypted storage and explicit access approval

Sharing Controls

SharePoint and OneDrive external sharing is restricted to approved external domains via DLP policy. Ad hoc external sharing of Confidential or Restricted files is prohibited without IT and management approval. Public link generation is disabled for all non-Public classified content.

Large File Transfers

Sending large files (over 25 MB) externally must use IT-approved methods: SharePoint external access links (time-limited) or managed file transfer via the approved tool in the application catalog. Consumer file-sharing services (Dropbox, WeTransfer, personal Google Drive) are prohibited for corporate data of any classification.

19

Backup and Recovery Procedures

Backup and recovery operations are critical to CoreAxis's business continuity posture. The following standards govern backup scope, frequency, retention, and testing.

Backup Scope

All production systems are in scope for backup, including:

- On-premises servers (Active Directory, file servers, application servers)
- Virtual machine images (VMware and Hyper-V)
- PostgreSQL databases (including WAL archiving for point-in-time recovery)
- Redis persistent data volumes
- Cloud-hosted virtual machines (AWS and Azure VM snapshots)

- Microsoft 365 data (Exchange, SharePoint, OneDrive) via a third-party Microsoft 365 backup solution

Backup Schedule

- Full backup: Weekly (Sunday 02:00–06:00 local time)
- Incremental backup: Daily (01:00–03:00 local time)
- Database transaction log backup: Every 4 hours for Tier 1 systems, every 24 hours for Tier 2
- VM snapshots: Daily for production VMs

Retention

- Daily backups: 30 days
- Weekly backups: 12 weeks
- Monthly backups: 12 months
- Annual backups: 7 years (for compliance-grade data)

Backup Storage

Primary backups are stored on-premises in a dedicated backup appliance. Offsite copy is replicated to an AWS S3 bucket in a different region using server-side encryption (SSE-S3 or SSE-KMS). Microsoft 365 backups are retained in the third-party backup provider's cloud storage with geo-redundancy.

Recovery Testing

Backup recovery is tested quarterly. The System Administrator performs a restore test on a non-production system and documents the result in Confluence. Annual DR exercises test full recovery of Tier 1 systems. Any backup failure must be logged and

investigated within 24 hours; unresolved backup failures for Tier 1 systems are escalated to the Head of IT.

Recovery Time and Point Objectives

- Tier 1 (Domain Controllers, primary databases): RTO 4 hours, RPO 4 hours
- Tier 2 (Application servers, secondary services): RTO 8 hours, RPO 24 hours
- Tier 3 (Non-critical services): RTO 24 hours, RPO 24 hours

20

Asset Management

All technology assets procured by or assigned to CoreAxis Technologies are tracked in the IT asset management system (maintained in Confluence and synchronized with the MDM platform for active devices).

Asset Registration

All physical assets (laptops, workstations, monitors, servers, network equipment, peripherals) are registered in the asset inventory at procurement time. Each asset record includes: asset tag, serial number, model, purchase date, purchase price, assigned user/location, warranty expiry, and disposal method when applicable.

Asset Tagging

Physical asset tags are affixed to all devices at provisioning. Tags contain a barcode encoding the asset ID cross-referenced in the inventory system. Asset tags must not be

removed. If an asset tag is damaged, the IT Administrator applies a replacement and updates the record.

Asset Inventory Audit

A full physical asset audit is conducted annually. IT staff physically verify the presence and condition of all registered assets. Discrepancies between the inventory and physical audit are investigated. Unresolved discrepancies involving high-value assets are reported to the Head of IT and Finance.

Software Asset Management

Software licenses are tracked alongside hardware in the asset inventory. License entitlements, usage counts, and expiry dates are recorded. License over-deployment (more installations than licenses) is treated as a compliance risk and resolved within 30 days of discovery.

Asset Disposal

Disposal of IT assets follows a three-step process:

1. **Data Sanitization:** All storage media is wiped using NIST 800-88-compliant methods (Secure Erase for SSDs, multi-pass overwrite for HDDs, degaussing for tapes). Certificates of data destruction are retained.

2. **Asset Deregistration:** The asset is marked as disposed in the inventory with date, method, and handler.

3. **Physical Disposal:** Assets are disposed of via an approved IT asset recycling vendor with documented chain of custody. Assets may not be disposed of in general waste.

21

Hardware Procurement Process

All IT hardware and software purchases must follow the procurement process outlined in this section. Unauthorized purchases are not reimbursable and may result in disciplinary action.

Procurement Initiation

Hardware and software procurement requests are submitted via the Jira procurement queue. The request must include: item description, quantity, business justification, estimated cost, and required delivery date. Requests must be approved by the requester's department head before IT review.

IT Review

The IT Administrator reviews all procurement requests against the following criteria:

- Compatibility with existing infrastructure and approved standards
- Security posture of the vendor and product (for software/SaaS)
- Availability in the approved vendor catalog
- Total cost of ownership including support and licensing

Approval Thresholds

- Under ₹50,000: IT Administrator approval
- ₹50,000–₹2,00,000: Head of IT approval
- Above ₹2,00,000: Head of IT + Finance Head joint approval
- Recurring SaaS subscriptions above ₹5,00,000/year: Board-level awareness required

Approved Vendors

CoreAxis maintains a preferred vendor list for hardware procurement covering major OEMs (Dell, HP, Lenovo, Apple) and local authorized distributors. Purchases from non-listed vendors require additional justification and Head of IT approval. All vendors undergo a vendor due diligence review per Section 34 before first engagement.

Delivery and Asset Registration

All delivered hardware is inspected by IT staff before acceptance. Serial numbers are verified against purchase orders. Assets are registered in the inventory system and assigned asset tags before deployment. Defective deliveries are returned through the vendor's documented return process within 5 business days.

Emergency Procurement

Emergency hardware requirements (failure replacement, critical incident support) may bypass standard approval timelines with verbal Head of IT approval, followed by written post-purchase approval within 24 hours. Emergency procurements are tracked and reported monthly to Finance.

IT Service Desk Procedures

The IT Service Desk is the primary point of contact for all IT support requests and incident reports from CoreAxis employees. It operates through the Jira Service Management portal.

Ticket Submission

Employees submit support requests via the Jira Service Management self-service portal or by emailing the IT helpdesk alias. Walk-up support at the IT desk is available during business hours but all requests must be logged in Jira even if resolved verbally or in person.

Ticket Categories

- **Service Request:** Standard, predictable requests (password reset, software installation, access request, peripheral replacement). No troubleshooting required.
- **Incident:** An unplanned interruption or degradation of an IT service.
- **Problem:** The root cause of one or more recurring incidents.
- **Change Request:** A request to make a modification to IT infrastructure, configuration, or services.

SLA Targets

| Priority | Description | First Response | Resolution |

|---|---|---|---|

| P1 – Critical | Service outage affecting business operations | 30 minutes | 4 hours |

| P2 – High | Significant impact to an individual or team | 2 hours | 8 hours |

| P3 – Medium | Moderate impact; workaround exists | 4 hours | 3 business days |

| P4 – Low | Minor request; no operational impact | 8 hours | 5 business days |

Ticket Escalation

Help Desk Engineers escalate tickets beyond their resolution authority to System Administrators, Network Engineers, or Cloud Administrators based on domain.

Escalated tickets retain their original SLA clock. The escalating engineer documents the steps taken and the reason for escalation.

Knowledge Base

Resolved tickets for recurring issues are documented as knowledge base articles in Confluence. Help Desk Engineers are expected to contribute a minimum of two knowledge base articles per quarter. Knowledge base articles reduce repeat ticket volumes and support self-service resolution.

23

Incident Management

Incident Management at CoreAxis Technologies follows a structured lifecycle to ensure rapid identification, containment, resolution, and post-incident review.

Incident Classification

Incidents are classified by severity at the time of triage:

- **Sec 1:** Total or near-total service outage; business operations halted.
Examples: domain controller failure, network backbone outage, ransomware event.
- **Sec 2:** Partial service disruption affecting a significant subset of users or a critical service. Examples: email delivery failure, VPN concentrator down, primary database degradation.
- **Sec 3:** Single-user or non-critical service impact. Examples: workstation hardware failure, individual application error.

Incident Response Lifecycle

1. **Detection:** Incident identified via monitoring alert, service desk ticket, or user report.
2. **Triage:** Help Desk or on-call engineer assesses severity and assigns ownership.
3. **Containment:** Immediate steps taken to prevent further impact.
4. **Investigation:** Root cause identification using logs, telemetry, and system state.
5. **Resolution:** Service restored; fix applied.
6. **Communication:** Affected parties notified at detection, at key milestones, and at resolution.
7. **Post-Incident Review (PIR):** Mandatory for Sev 1 and Sev 2 incidents. PIR must be completed within five business days of resolution.

Security Incidents

Security incidents (malware, data breach, unauthorized access, phishing compromise) follow a parallel Information Security incident response process. IT's role in security incidents is containment and evidence preservation. The Information Security team leads investigation and response. No affected system may be rebuilt or wiped without Information Security sign-off.

Post-Incident Review

PIRs are documented in Confluence using the standard PIR template. They include: incident timeline, root cause, contributing factors, impact assessment, actions taken, and preventive measures. PIR action items are tracked in Jira with assigned owners and due dates.

24

Change Management

All changes to production IT systems, infrastructure, and configurations at CoreAxis Technologies must follow the Change Management process to minimize risk and maintain operational stability.

Change Categories

- **Standard Change:** Pre-approved, low-risk, repeatable changes with documented procedures (e.g., routine patching, password resets, certificate renewals). Implemented without CAB review.

- **Normal Change:** Changes requiring CAB review and approval before implementation. Low to medium risk.
- **Significant Change:** High-impact changes (infrastructure redesign, major version upgrades, security architecture changes). Requires full CAB review, extended testing, and Head of IT sign-off.
- **Emergency Change:** Urgent changes required to restore service or prevent an imminent security incident. Implemented with available approver sign-off; post-hoc CAB review within 24 hours.

Change Request Process

1. Requester submits a Change Request (CR) in Jira with: change description, justification, risk assessment, rollback plan, implementation steps, test plan, and affected systems.
2. The IT Administrator conducts an initial review for completeness within two business days.
3. The CAB reviews and approves or rejects the CR at the weekly CAB meeting. Requesters may attend to clarify.
4. Approved CRs are scheduled in the Change Calendar. Changes to production systems are preferred during low-traffic windows (20:00–06:00 IST or weekends for significant changes).
5. Change is implemented per the approved plan. Deviations from the approved plan must be reported immediately; the change may need to be rolled back if deviations cannot be resolved on the fly.

6. Post-implementation review is completed within 24 hours confirming success or documenting issues.

Rollback Requirements

Every change must have a documented, tested rollback plan. Changes without a viable rollback plan are rejected. The rollback must be executable within the change window.

Change Freeze Periods

Change freezes are in effect during: financial year-end (last two weeks of March), major product release windows communicated by Engineering, and public holidays.

Emergency changes during freeze periods require Head of IT and CISO joint approval.

25

Patch Management

CoreAxis Technologies operates a risk-based patch management program covering operating systems, firmware, applications, and network device software.

Patch Tiers and SLAs

Patches are categorized by CVSS severity:

- **Critical (CVSS ≥ 9.0):** Patch within 72 hours of release for internet-facing systems; within 7 days for internal systems.
- **High (CVSS 7.0–8.9):** Patch within 14 days.
- **Medium (CVSS 4.0–6.9):** Patch within 30 days.
- **Low (CVSS < 4.0):** Patch within 90 days or next quarterly maintenance window.

Patch Deployment Process

1. **Identification:** Patches are identified via vendor advisories, Microsoft Update, Ubuntu Security Notices, and the vulnerability management platform.
2. **Testing:** Patches are deployed to a test environment before production. Critical patches may be accelerated with abbreviated testing for internet-facing systems.
3. **Scheduling:** Non-critical patches are deployed during approved maintenance windows. Patch schedules are published in the Change Calendar.
4. **Deployment:** Windows patches are deployed via Windows Update for Business; Linux updates are applied via `unattended-upgrades` (auto) and manual review cycles; application patches are deployed via the application deployment toolchain.
5. **Verification:** Post-patch compliance is verified via the vulnerability management scanner within 48 hours.

Exceptions

Systems that cannot be patched within the SLA due to compatibility constraints require an exception approved by the Head of IT and Information Security. Exceptions must document the risk acceptance, compensating controls, and a target remediation date.

Firmware and Network Device Patching

Firmware updates for servers (BIOS, iDRAC, iLO) and network devices are reviewed quarterly and deployed following the Change Management process. Network device updates are performed during off-hours with rollback configurations prepared in advance.

26

Endpoint Security

Endpoint security at CoreAxis Technologies is implemented through a layered approach combining encryption, MDM-enforced configuration baselines, EDR, and continuous monitoring.

Encryption

- **Windows:** BitLocker full-disk encryption with TPM 2.0 binding. Recovery keys are escrowed to Microsoft Entra ID. Pre-boot authentication is required for high-security roles.
- **Linux:** LUKS full-disk encryption at installation. Recovery passphrases are stored in the IT secrets manager.
- **Removable Media:** USB storage device access is restricted via MDM policy. Where USB access is required for a legitimate role, specific authorized device classes may be whitelisted; unrecognized USB storage is blocked.

Screen Lock and Session Policy

- Screen lock activates after 5 minutes of inactivity for all managed devices
- After 15 minutes of inactivity, the screen locks and requires re-authentication
- VPN sessions idle for 30 minutes are disconnected

USB and Removable Media Policy

The use of personal USB storage devices on corporate systems is prohibited. Data transfer to removable media requires explicit IT authorization, documented in a service request. Removable media used for authorized transfers must be encrypted.

Endpoint Configuration Baseline

All managed endpoints must conform to the IT configuration baseline enforced via MDM and Group Policy. Deviations from the baseline are flagged in the compliance dashboard and remediated within the standard patching SLA. Key baseline elements include: disabled AutoRun, Windows Defender enabled (or CrowdStrike installed), host firewall enabled, and PowerShell script block logging active.

Application Control

On high-security endpoints (finance, executive, IAM administrators), application whitelisting (Windows Defender Application Control or AppLocker) restricts executable launches to signed, approved applications. For standard endpoints, the approved software catalog and software restriction policies apply.

Antivirus and Endpoint Detection

CoreAxis Technologies operates endpoint protection across two layers: antivirus (AV) for signature-based threat detection and Endpoint Detection and Response (EDR) for behavioral threat detection and incident response capability.

Antivirus

Microsoft Defender Antivirus is the baseline AV solution deployed on all Windows endpoints. Defender is centrally managed via Microsoft Defender for Endpoint (MDE).

Configuration requirements:

- Real-time protection must remain enabled at all times
- Cloud-delivered protection and automatic sample submission are enabled
- Signature updates are pushed daily via MDE
- Scheduled full scans run weekly (Saturday 03:00)

Endpoint Detection and Response

CrowdStrike Falcon is deployed on all endpoints as the primary EDR platform. Falcon Insight provides continuous monitoring for behavioral indicators of compromise (IOCs), lateral movement, process injection, and credential theft. Configuration:

- Prevention policy is set to moderate-aggressive; detections are reviewed daily by the Information Security team
- Sensor tamper protection is enabled; disabling the sensor requires IT Administrator credentials and is logged
- Threat graph telemetry is retained for 90 days

EDR Alerts and Response

CrowdStrike Falcon alert tiers:

- **Critical/High alerts:** Paged to the on-call IT Administrator immediately; Information Security is notified within 15 minutes.
- **Medium alerts:** Reviewed by the IT Administrator within 4 business hours.
- **Informational/Low alerts:** Reviewed in daily batch during business hours.

Endpoints generating a Critical alert are automatically isolated from the network (network containment) via the Falcon console pending investigation. Isolated endpoints must not be released from containment without Information Security sign-off.

Exclusions

AV and EDR exclusion requests for development tooling (false positive suppression) must be submitted to the IT Administrator with full justification and reviewed by Information Security. Exclusions are documented and reviewed quarterly. Blanket directory exclusions are prohibited; exclusions must be as specific as possible (process name, file hash, or signature).

28

Software Licensing

CoreAxis Technologies is committed to full compliance with all software licensing agreements. The IT Administrator is responsible for maintaining license records and ensuring the organization does not operate in a state of license deficit.

License Inventory

All software licenses are recorded in the IT asset management system with: product name, version, license type, seat count, license key (stored in vault), expiry date, vendor, and cost. The inventory is reconciled monthly against deployment data from MDM and usage logs.

License Types in Use

- **Volume Licensing (Microsoft):** Microsoft 365, Windows 11 Enterprise, Windows Server — managed under Microsoft Volume Licensing Service Center (VLSC)
- **Named User Licenses:** JetBrains IDEs, CrowdStrike Falcon, Jira, Confluence, GitHub Enterprise — tracked per assigned user
- **Site Licenses:** Applicable tools with unlimited-user site agreements — usage still tracked for renewal planning
- **Open Source:** Open source software is tracked separately. Licenses with copyleft conditions (GPL, LGPL) are reviewed by the IT Administrator and Legal before use in product code

License Compliance

Deployment counts are compared against entitlements quarterly. License shortfalls are remediated within 30 days through additional purchases. Software installed on devices without a valid license is removed immediately upon discovery. Installation of pirated or cracked software by any employee results in immediate disciplinary action.

Vendor Audits

Software vendors may request usage audit data. The IT Administrator responds to vendor audit requests within the timeframe specified in the relevant license agreement, typically 30 days. Audit preparation uses deployment data from MDM and Active Directory reports. Employees must cooperate with audit data collection.

Open Source License Review

Open source components used in CoreAxis products are tracked by Engineering teams. IT supports the OSS license review process for infrastructure tooling. Components with incompatible licenses for commercial use must be replaced or a legal exception obtained before production deployment.

29

Cloud Infrastructure Guidelines

CoreAxis Technologies operates cloud infrastructure across Amazon Web Services (AWS) and Microsoft Azure. All cloud resources are subject to the governance, security, and cost standards defined in this section.

Cloud Governance Framework

Cloud accounts are organized using AWS Organizations (multi-account) and Azure Management Groups. Environments are segregated by account/subscription:

- Production (tightly controlled, minimal human access)
- Staging/UAT (mirrors production configuration; used for integration testing)
- Development (flexible; developer access granted per team)

- Shared Services (networking, logging, identity — landing zone account)

Access Control

Human access to cloud environments uses federated identity via Entra ID SSO. No standalone cloud IAM users are created for human access. Service accounts use cloud-native service principals or IAM roles with least-privilege policies. Root/Owner account credentials are stored in the IT secrets vault and accessed only for break-glass scenarios.

Resource Provisioning

All new cloud resources must be provisioned via approved Infrastructure-as-Code (IaC) templates (Terraform or Bicep). Manual console provisioning in production is prohibited except for emergency response. IaC code is maintained in GitHub Enterprise and reviewed before merge. Resource tagging is mandatory: tags include Environment, Owner, CostCenter, and Project.

Cost Governance

Budget alerts are configured at 80% and 100% of monthly estimates per account. Actual spend is reviewed weekly by the Cloud Administrator and monthly with Finance. Unused resources (stopped VMs for 30+ days, unattached storage volumes, orphaned load balancers) are reviewed monthly and decommissioned unless an exception is filed.

Cloud Security Posture

AWS Security Hub and Microsoft Defender for Cloud are enabled in all accounts with findings exported to the central SIEM. High-severity findings must be remediated within

7 days. Public-facing storage buckets/blob containers require explicit approval and are subject to weekly review.

30

Virtual Machines and Servers

CoreAxis Technologies uses virtualization to consolidate on-premises server infrastructure and provide flexible cloud-hosted workloads.

On-Premises Virtualization

VMware vSphere is the primary on-premises virtualization platform. Microsoft Hyper-V is used for Windows Server Hyper-V hosts where applicable. Standards:

- All production VMs run on hosts in a VMware vSphere cluster with vMotion and HA enabled
- vCenter Server access requires a dedicated administrative account, not a standard user account
- VM snapshots are for temporary purposes only (change rollback); snapshots older than 72 hours are flagged for review and deleted after 7 days
- VM templates are stored in the content library and refreshed quarterly

Server Provisioning

New server requests are submitted via Jira. The System Administrator provisions from an approved template, configures hostname, IP (registered in DNS and IPMI inventory),

and applies the baseline hardening policy. Server documentation (purpose, owner, OS version, open ports) is updated in Confluence within 24 hours of provisioning.

Server Hardening Baseline (Linux)

- Remove all unnecessary packages
- Disable unused services (systemd unit files)
- Configure host firewall (iptables/nftables) with default-deny inbound
- Disable root SSH login; use key-based authentication only
- Configure rsyslog or journald forwarding to the central log collector
- Apply CIS Level 1 benchmark

Server Hardening Baseline (Windows Server)

- Remove unused Windows roles and features
- Enable Windows Defender and configure centrally via MDE
- Restrict RDP to management network only; enable NLA
- Configure Windows Firewall with default-deny inbound
- Enable PowerShell script block logging, transcription
- Apply CIS Level 1 benchmark

End-of-Life Server Decommissioning

Servers scheduled for decommissioning go through a 30-day notice period communicated to all stakeholders. Data is migrated or archived, DNS entries are removed, firewall rules are cleaned up, and storage is wiped. The asset record is updated to decommissioned status.

Logging and Monitoring

Comprehensive logging and monitoring are fundamental to CoreAxis's operational visibility and security incident detection capabilities.

Log Sources

The following sources are configured to forward logs to the central SIEM:

- Active Directory / Entra ID audit logs and sign-in logs
- Azure Monitor and AWS CloudTrail
- Network firewall and IDS/IPS event logs
- DNS query logs
- VPN connection and authentication logs
- Endpoint telemetry (CrowdStrike Falcon, MDE)
- Server OS logs (syslog/Windows Event Log)
- Application logs (FastAPI, Nginx access/error logs)
- Database audit logs (PostgreSQL pg_audit extension)

Log Retention

Log retention aligns with the following policy:

- Security event logs: 12 months (hot storage), 36 months (cold/archived)
- Application logs: 90 days
- Network flow logs: 30 days
- Audit/compliance logs: 7 years

Infrastructure Monitoring

Infrastructure monitoring is implemented using an agent-based monitoring platform.

Dashboards cover:

- Server CPU, memory, disk, and network utilization
- Virtualization platform health (vSphere cluster, Hyper-V hosts)
- Database performance (PostgreSQL: query execution time, connection pool, replication lag)
- Network device health (interface errors, bandwidth saturation, BGP sessions)
- Cloud resource health and cost anomaly detection

Alerting

Alerts are configured in the monitoring platform for threshold breaches and anomalous conditions. Alert routing:

- P1/Sev1-equivalent alerts: PagerDuty on-call rotation for immediate response
- P2/Sev2: Email and Slack notification to IT channel
- P3/P4: Jira ticket auto-created for review during business hours

Monitoring Review

Alert thresholds are reviewed quarterly to reduce noise and improve signal fidelity. False positives are documented and threshold adjustments are made through the Change Management process.

32

Business Continuity Support

The IT department supports CoreAxis Technologies' Business Continuity Plan (BCP) by ensuring that critical IT services can continue to operate or be rapidly restored following a disruptive event.

IT's Role in BCP

The IT department is responsible for:

- Identifying and classifying IT systems and services by criticality (Tier 1, 2, 3)
- Defining and maintaining recovery time objectives (RTO) and recovery point objectives (RPO) for all classified systems
- Implementing technical resilience measures (redundancy, failover, backup)
- Executing the IT recovery runbooks during a declared business continuity event
- Participating in BCP exercises and post-exercise reviews

Critical System Classification

- **Tier 1 (Mission Critical):** Active Directory / Entra ID, primary email service (Exchange Online), core network infrastructure, production databases, VPN services, GitHub Enterprise.
- **Tier 2 (Business Critical):** Jira, Confluence, Slack, internal monitoring, secondary databases.
- **Tier 3 (Important):** Non-production environments, peripheral services, developer tooling.

Technical Resilience Measures

- Tier 1 systems are deployed with N+1 redundancy minimum

- Active Directory domain controllers are deployed across both offices
- Core network links are dual-homed with automatic failover
- Cloud-hosted Tier 1 services are deployed across multiple availability zones
- Internet connectivity at each office uses dual ISP links with automatic failover

BCP Testing

The IT department participates in at least one full BCP tabletop exercise per year and one technical recovery test per year. Test results are documented and improvement actions are tracked in Jira. Lessons learned are incorporated into updated runbooks within 30 days of the exercise.

33

Disaster Recovery Support

The IT Disaster Recovery (DR) plan defines the procedures for restoring IT infrastructure and services following a catastrophic event such as data center failure, ransomware attack, or physical site loss.

DR Scope and Approach

CoreAxis employs a cloud-first DR strategy. The primary recovery target for on-premises infrastructure failure is the organization's cloud environment (AWS and Azure). Critical systems have documented runbooks for cloud-hosted recovery. The DR plan does not assume any on-premises facilities are available in the worst-case scenario.

Recovery Runbooks

Runbooks exist for each Tier 1 and Tier 2 system, maintained in Confluence. Each runbook includes:

- Prerequisites and dependencies
- Step-by-step recovery procedure with commands and screenshots
- Verification steps confirming service restoration
- Estimated recovery time
- Responsible role (who executes this runbook)

Runbooks are reviewed and tested annually. Outdated runbooks are flagged and updated before the DR test.

DR Testing

Annual DR tests involve:

1. Simulated loss of on-premises infrastructure (network isolation test)
2. Recovery of at least two Tier 1 systems from backup to cloud environment
3. Validation of user access and key business functions in the recovered environment
4. Documentation of time-to-recover and gaps identified

The Head of IT approves the DR test plan, and results are reviewed with senior leadership.

Communication During DR

The IT department maintains an out-of-band communication plan (mobile phone tree, personal email as fallback, emergency Slack workspace on personal devices) for use when primary communication systems are unavailable. Key contact information and the communication plan are stored offline and accessible without internet access.

Post-DR Review

Following any declared DR event, a formal post-event review is conducted within 10 business days. Findings and improvement actions are tracked through Jira.

34

Vendor Management

CoreAxis Technologies maintains structured vendor management practices to ensure that third-party technology vendors and service providers meet the organization's security, reliability, and compliance standards.

Vendor Onboarding

Before engaging a new IT vendor or SaaS provider, the IT Administrator conducts a vendor due diligence assessment covering:

- Security posture (SOC 2 Type II, ISO 27001, or equivalent certification)
- Data processing location and sovereignty compliance
- Sub-processor disclosures (for services handling CoreAxis data)

- Incident notification commitments
- Business continuity and disaster recovery capabilities
- Financial stability of the vendor

Vendors handling Confidential or Restricted data require a Data Processing Agreement (DPA) executed before any data is shared.

Approved Vendor Register

The IT department maintains an approved vendor register in Confluence. All IT procurement must be from registered vendors unless an exception is approved by the Head of IT.

SLA and Contract Management

Vendor SLAs are tracked by the IT Administrator. SLA breaches are escalated to the vendor in writing and tracked to resolution. Recurring SLA failures trigger a vendor review, which may include contract renegotiation or replacement.

Annual Vendor Review

Critical vendors (those providing Tier 1 services or handling sensitive data) are reviewed annually. The review assesses: service performance against SLAs, security certification currency, outstanding issues, and contract renewal terms. Review outcomes are documented and shared with the Head of IT.

Vendor Termination

When terminating a vendor relationship, IT coordinates data retrieval and deletion confirmation, credential revocation, and contract closure. Vendor access to CoreAxis

systems is revoked on the termination date. A data deletion certificate is obtained from vendors handling Confidential or above data.

35

Documentation Standards

All IT documentation is maintained in Confluence under the IT Knowledge Base space. Documentation is a professional obligation, not an optional activity.

Documentation Requirements

The following documentation types must exist and be current for all production systems:

- **System Overview:** Purpose, owner, primary users, dependencies, hosting location
- **Architecture Diagram:** Network topology, system context diagram, data flow diagram
- **Configuration Documentation:** Key configuration files, security settings, integration points
- **Operational Runbooks:** Step-by-step procedures for routine operations, maintenance, and recovery
- **Change Log:** Record of significant changes to the system or configuration

Documentation Standards

- Documentation is written in clear, direct language. Avoid jargon where simpler terms suffice.
- Diagrams use Confluence's built-in diagramming tool or draw.io; PowerPoint or Word diagrams are not acceptable.
- All documentation must include: title, author, date created, date last reviewed, and review cycle.
- Configuration documentation must not include credentials, passwords, or private keys. References should point to the secrets manager.
- Documentation is reviewed at least annually. The IT Administrator assigns ownership and tracks overdue reviews.

Runbook Quality Standards

Runbooks must be written to a standard where a competent IT professional who has never worked on the system could execute the procedure successfully. Ambiguous steps must be clarified or broken into sub-steps.

Change-Driven Documentation

Every approved Change Request must include an update to relevant documentation as part of its implementation plan. The Change Manager (IT Administrator) verifies documentation is updated as a post-implementation check.

Collaboration with Other Departments

The IT department operates as a service function and regularly collaborates with all CoreAxis departments. Effective collaboration requires clear interfaces and agreed workflows.

Human Resources

- Onboarding: HR provides confirmed start dates and role details a minimum of 5 business days in advance. IT provisions accounts, devices, and access based on the HR-submitted onboarding form.
- Offboarding: HR notifies IT of departures per the timelines in Section 9. IT completes the offboarding checklist and provides confirmation to HR.
- Leave and Absence: Extended leave (over 30 days) triggers a temporary account suspension per the dormant account policy.

Information Security

- IT and InfoSec collaborate on endpoint security, incident response, vulnerability management, and compliance activities.
- InfoSec defines security requirements; IT implements them.
- Security policy changes initiated by InfoSec go through the standard Change Management process.
- Joint incident response exercises are conducted semi-annually.

AI & Machine Learning / Software Engineering

- IT provides infrastructure for development environments, CI/CD pipelines, and model training infrastructure.
- Infrastructure requirements for new projects are submitted via Jira 10 business days before expected need.

- IT participates in architecture reviews for new products to ensure infrastructure supportability.

Finance

- IT submits quarterly and annual budget forecasts. Finance approves expenditures per the procurement thresholds.
- Asset purchases are reported to Finance for capitalization within 10 business days of delivery.
- IT supports Finance during audit activities by providing system access logs, license records, and asset inventories.

Senior Leadership

- The Head of IT provides a monthly IT health dashboard to senior leadership covering: service availability, security posture, open incidents, budget vs. actuals, and strategic initiatives.

37

Employee Responsibilities

All CoreAxis employees — not only IT staff — carry responsibilities for the security and proper use of IT assets and services. The policies in this handbook apply to every employee who uses CoreAxis IT resources.

Acceptable Use

Corporate IT resources are provided for business purposes. Employees may use systems for incidental personal use provided it does not involve:

- Storage or transmission of illegal content
- Access to or distribution of adult content
- Circumventing security controls
- Activities that could embarrass or create legal liability for CoreAxis

Security Responsibilities

Employees are required to:

- Complete mandatory information security awareness training annually
- Report suspicious emails (phishing, impersonation) to IT/InfoSec immediately using the report phishing mechanism in Outlook/Gmail
- Lock their workstation screen when leaving their desk, even briefly
- Not share their credentials with any other person, including IT staff (IT staff will never ask for a password)
- Report lost or stolen devices within four hours
- Keep their device compliant with the MDM configuration; do not disable or circumvent security controls
- Use the corporate password manager for all account credentials

Data Handling Responsibilities

Employees are responsible for correctly classifying documents they create and handling them per the data classification policy. Employees must not store corporate data on personal devices or personal cloud storage accounts.

Violation Reporting

Employees who observe or suspect a policy violation, security incident, or data breach must report it to IT or Information Security immediately. Reports may be made anonymously through the HR whistleblower channel. Employees who report in good faith are protected from retaliation.

Consequences of Non-Compliance

Policy violations may result in disciplinary action up to and including termination. In cases involving illegal activity, violations may be reported to law enforcement.

38

Continuous Improvement

The IT department is committed to continuously improving the quality, efficiency, and security of IT services at CoreAxis Technologies.

Performance Metrics

The IT department tracks and reports the following metrics monthly:

- Service desk ticket volume by category and priority
- SLA compliance rate (target: ≥95% of tickets resolved within SLA)
- Mean time to resolve (MTTR) by priority tier
- Change success rate (changes with no unplanned rollback)

- Patch compliance rate (target: ≥98% of endpoints current)
- Backup success rate (target: 100% of jobs successful)
- System availability for Tier 1 services (target: ≥99.5%)
- Open vulnerability count by severity

Improvement Process

Improvement opportunities are identified through:

- Post-incident reviews (Section 23)
- Service desk trend analysis (recurring ticket categories)
- Staff suggestions via the IT improvement suggestion box in Jira
- External benchmarking against industry standards
- Audit findings and penetration test results

Identified improvements are logged in the IT improvement backlog in Jira. The Head of IT prioritizes the backlog quarterly. Improvements are implemented through the standard Change Management process.

Technology Refresh

The IT department maintains a technology roadmap covering planned upgrades, end-of-life migrations, and new capability introductions over a rolling 18-month horizon. The roadmap is reviewed and updated quarterly. Major roadmap items are shared with department heads for business planning purposes.

Staff Development

IT staff are expected to maintain current knowledge and hold relevant industry certifications. The department supports professional development through funded

training, certification examination costs, and participation in professional communities. Each IT staff member has an individual development plan reviewed annually.

39

Appendix

This appendix consolidates reference information, quick-reference tables, and glossary entries supporting the main body of this handbook.

A. Glossary

Active Directory (AD): Microsoft's on-premises directory service for authentication and authorization.

Conditional Access: Entra ID policy engine that enforces access controls based on signals such as user identity, device compliance, location, and risk level.

CIS Benchmark: Security configuration guidelines published by the Center for Internet Security, used as CoreAxis's hardening standard for operating systems and network devices.

CVSS: Common Vulnerability Scoring System — a standardized method for rating the severity of security vulnerabilities.

EDR: Endpoint Detection and Response — security tooling that provides behavioral threat detection and investigation capabilities on endpoints.

Entra ID: Microsoft's cloud-based identity and access management service (formerly Azure Active Directory).

IaC: Infrastructure-as-Code — the practice of managing and provisioning infrastructure through machine-readable configuration files rather than manual console operations.

LUKS: Linux Unified Key Setup — the standard disk encryption specification for Linux systems.

MDM: Mobile Device Management — a platform for centrally managing device configuration, compliance, and security on enrolled endpoints.

MFA: Multi-Factor Authentication — authentication requiring two or more verification factors from different categories.

MTTR: Mean Time to Resolve — the average time from incident detection to resolution.

PIM: Privileged Identity Management — Microsoft Entra ID feature for time-limited, approval-workflow-based activation of privileged roles.

RBAC: Role-Based Access Control — access control model where permissions are assigned to roles, and roles are assigned to users.

RPO: Recovery Point Objective — the maximum tolerable data loss period in the event of a disaster.

RTO: Recovery Time Objective — the maximum tolerable period for service restoration following a disaster.

SIEM: Security Information and Event Management — a platform that aggregates and correlates log and event data for security monitoring.

WAL: Write-Ahead Log — PostgreSQL's mechanism for transaction durability and point-in-time recovery.

B. Key Contacts

Role	Contact Method
IT Service Desk	Jira Service Management portal helpdesk@coreaxis.com
Head of Information Technology	it-head@coreaxis.com
Information Security Team	infosec@coreaxis.com

All emergency contacts and escalation paths are maintained in the IT Emergency Contacts document in Confluence (IT Knowledge Base > Emergency Contacts). This document is reviewed and updated quarterly.

C. Approved Technology Reference

Category	Approved Technologies
Desktop OS	Windows 11 Enterprise, Ubuntu Linux 22.04 LTS
Server OS	Windows Server 2022, Ubuntu Server 22.04/24.04 LTS
Identity	Microsoft Entra ID, Active Directory
Productivity Suite	Microsoft 365, Google Workspace
Communication	Microsoft Teams, Slack
Project / Docs	Jira, Confluence

Code Repository	GitHub Enterprise
Virtualization	VMware vSphere, Microsoft Hyper-V
Cloud	AWS, Microsoft Azure
Containers	Docker Desktop (dev), Kubernetes (prod via cloud)
EDR	CrowdStrike Falcon, Microsoft Defender for Endpoint
Encryption	BitLocker (Windows), LUKS (Linux)
Databases	PostgreSQL, Redis
Web Server / Proxy	Nginx
API Framework	FastAPI
Remote Access	IT-managed VPN (vendor per procurement), SSH

D. Document Revision History

Version	Date	Author	Changes
1.0	01 January 2025	Head of Information Technology	Initial release

This document is reviewed annually. Material changes to IT infrastructure, policy requirements, or regulatory obligations may trigger an off-cycle review. All revisions are tracked in this table and communicated to relevant IT staff upon publication.